

מודול 1 — מבוא, מעבדה ומתודולוגיה

חומר לימוד

1 יחידות

תוכן העניינים

1. מודול 1 — מבוא, המעבדה ומתודולוגיה

מודול 1 — מבוא, המעבדה ומתודולוגיה

מטרות המודול: בסיום המודול תבין מהו האקינג אתי לעומק, תכיר את סוגי ההאקרים וסוגי בדיקות החדירה, תשלוט במתודולוגיית חמשת השלבים, תקים מעבדה וירטואלית מבודדת ותפעילה, ותתמצא ב-Kali Linux ובארגז הכלים שלו.

קבצים במודול: README.md (חומר לימוד) · missions.md (תרגילים) · solutions.md (פתרונות) · practice.md (תרגול) · slides.md (מצגת).

תוכן העניינים

0. פתיחה — סיפורים שישנו את העולם 🎬
1. מהו האקינג אתי
2. סוגי האקרים (Threat Actors)
3. סוגי בדיקות חדירה
4. מושגי יסוד וטרמינולוגיה
5. חמשת שלבי ההאקינג האתי
6. היבטים משפטיים ואתיים
7. הקמת המעבדה
8. סקירת Kali Linux
9. סיכום ומילון מונחים

פתיחה — סיפורים שישנו את העולם 🎬

לפני ההגדרות והכלים — בואו נדבר על **למה** התחום הזה כל כך מרתק. כל סיפור כאן הוא אירוע אמיתי ששינה את העולם, וכל אחד מהם מתחבר ישירות למשהו שתלמדו בקורס הזה. 🌍

🐛 תולעת מוריס — הפעם הראשונה שהאינטרנט "נפל" (1988)

סטודנט בן 23 מאוניברסיטת קורנל בשם רוברט מוריס כתב תוכנית קטנה שנועדה רק "למדוד את גודל האינטרנט". באג אחד בקוד גרם לה להשתכפל בטירוף — ותוך שעות היא שיתקה כ-6,000 מחשבים, **בערך 10% מכל האינטרנט של אז**. מוריס היה הראשון בהיסטוריה שהורשע לפי חוק הפריצה למחשבים בארה"ב.

היום? הוא פרופסור מכובד ב-MIT. < **בקורס:** כך בדיוק מתפשטות תולעות ו-Exploits — נלמד את המנגנון במודולים 6-7.

ILOVEYOU — מכתב האהבה שהדביק 50 מיליון מחשבים (2000)

בוקר אחד קיבלו מיליוני אנשים מייל עם הכותרת "ILOVEYOU" וקובץ מצורף בשם "מכתב אהבה". כל מי שפתח — הקבצים שלו נחקו, והתולעת שלחה את עצמה לכל אנשי הקשר שלו. **50 מיליון מחשבים תוך 10 ימים, נזק של ~10 מיליארד דולר.** לא חולשה טכנית מתוחכמת — פשוט אנשים שסקרנים מדי ללחוץ. < **בקורס:** זהו הגורם האנושי — **הנדסה חברתית ופשינג** (מודול 15). האדם הוא תמיד החוליה החלשה.

Stuxnet — כשקוד הרס מכונות אמיתיות (2010)

נשק הסייבר הראשון בעולם שגרם **נזק פיזי**. תולעת מתוחכמת להפליא חדרה למתקן הגרעין באיראן, קפצה בין רשתות מבודדות דרך דיסקים-און-קי, וגרמה לצנטריפוגות להסתובב במהירות מטורפת עד שהרסו את עצמן — בזמן שהמסכים הראו למפעילים שהכול תקין. < **בקורס:** קוד יכול לחצות מהעולם הדיגיטלי לעולם הפיזי. זו העוצמה — וזו האחריות.

WannaCry — הכופרה ששיתקה בתי חולים (2017)

תוך ימים ספורים נדבקו **מעל 200,000 מחשבים ב-150 מדינות**. הכופרה הצפינה קבצים ודרשה כופר בביטקוין. היא שיתקה בתי חולים בבריטניה — ניתוחים בוטלו, מטופלים הופנו לבתי חולים אחרים. איך היא התפשטה? דרך חולשה בשם **EternalBlue** (בפרוטוקול SMB) שדלפה מה-NSA. מיליוני מערכות פשוט לא עדכנו את התיקון שכבר היה זמין. < **בקורס:** במודול 6 **תסרקו בעצמכם** מערכות ותחפשו את החולשה MS17-010 — **אותה חולשה בדיוק** ש-WannaCry ניצלה.

Mirai — הצבא של המצלמות (2016)

קבוצת סטודנטים בנתה רשת בוטים שהשתלטה על **מאות אלפי מכשירי IoT** — מצלמות אבטחה, ראוטרים — פשוט על-ידי ניסיון סיסמאות ברירת מחדל כמו `admin/admin`. ואז הפעילה מתקפה שהפילה את **Twitter, Netflix, Reddit** ו-Spotify בבת אחת ברחבי ארה"ב. < **בקורס:** סיסמאות חלשות וברירת מחדל — **מתקפות סיסמאות** (מודול 8). כלל אצבע: אם לא שינית את הסיסמה, מישו כבר יודע אותה.

Equifax — 147 מיליון גנובים בגלל תיקון אחד שנשכח (2017)

אחת הפריצות החמורות בהיסטוריה: פרטים אישיים (כולל מספרי זהות) של **147 מיליון בני אדם** נגנבו. הסיבה? חולשה **אחת** ברכיב תוכנה (Apache Struts) שהתיקון עבורה היה זמין כבר חודשים — ופשוט לא הותקן. < **בקורס:** רכיבים פגיעים ועדכונים — **אבטחת Web** (מודול 9) וחקר חולשות (מודול 6).

קווין מיטניק — ההאקר המבוקש שהפך למגן 🧑🏻💻

ההאקר המפורסם בעולם בשנות ה-90. הוא פרץ לעשרות חברות — אך לרוב לא דרך קוד, אלא דרך אנשים: שיחת טלפון משכנעת, התחזות, וקצת ביטחון עצמי. הוא היה על רשימת המבוקשים של ה-FBI, ישב 5 שנים בכלא — והיום הוא יועץ אבטחה מבוקש ומרצה. המסע מ"הרשע" ל"מגן" הוא בדיוק המסע של הקורס הזה. < 🙌 בקורס: הכלי החזק ביותר הוא לפעמים פשוט לדעת לדבר עם אנשים.

ולמה כדאי לכם? התחום שמשלם 💰

- האקרים אתיים הם מהמקצועות המבוקשים ביותר בהייטק — מחסור עולמי של מיליוני אנשי אבטחה.
- **Bug Bounty**: חברות כמו Google, Facebook ו-Appl משלמות להאקרים שמוצאים אצלן חולשות — יש בני 17 שהרוויחו מאות אלפי דולרים מהחדר בבית.
- אתם מתחילים מאפס — ובסוף הקורס תבצעו בדיקת חדירות מלאה בעצמכם. 🚀

🎯 **המטרה שלנו:** בכל אחד מהסיפורים לעיל, אילו האקר אתי היה בודק את המערכת מראש — האסון היה נמנע. זה מה שאתם הולכים ללמוד לעשות.

1.1 מהו האקינג אתי (Ethical Hacking)?

האקינג אתי הוא תהליך מורשה וחוקי של הערכת אבטחת מערכת, רשת או אפליקציה, על-ידי סימולציה של תקיפה אמיתית — במטרה למצוא חולשות (Vulnerabilities) לפני שתוקף זדוני ינצל אותן. המבצע נקרא **בודק חדירות (Penetration Tester / Pentester)** או **האקר אתי (Ethical Hacker)**.

הרעיון המרכזי: כדי להגן על מערכת, צריך לחשוב כמו התוקף. ההאקר האתי משתמש באותם כלים ובאותן **טכניקות** של הפושע — אך בהבדל מהותי אחד: **הרשאה**.

שלושת עמודי התווך של המקצוע — CIA Triad

כל עולם אבטחת המידע נשען על שלושה עקרונות. מטרת התוקף היא לפגוע באחד מהם, ומטרת ההאקר האתי היא לוודא שהם מוגנים:

עיקרון	פירוש	דוגמה לפגיעה
Confidentiality (סודיות)	רק מורשים רואים את המידע	דלף מסד נתונים של סיסמאות
Integrity (שלמות)	המידע לא שונה ללא הרשאה	שינוי סכום בהעברה בנקאית
Availability (זמינות)	המערכת זמינה למשתמשים	מתקפת מניעת שירות (DoS)

💡 **דוגמה מהחיים:** כשבודק חדירות מוצא שאפשר לקרוא קבצים של משתמשים אחרים — זו פגיעה ב-Confidentiality. כשהוא מראה שאפשר לשנות הרשאות — זו פגיעה ב-Integrity. כל ממצא בדוח מסווג לפי העיקרון שנפגע.

ההבדל בין האקר אתי לתוקף זדוני

ההבדל אינו בכלים — הוא בהרשאה ובכוונה:

האקר אתי (White Hat)	תוקף זדוני (Black Hat)	
חווה והסכמה בכתב	ללא הרשאה	הרשאה
תיקון וחיזוק ההגנה	גניבה, נזק, רווח	מטרה
דוח מפורט ללקוח	הסתרת עקבות	תיעוד
חוקי	עבירה פלילית	חוקיות

1.2 סוגי האקרים (Threat Actors)

בעולם האמיתי יש קשת של “שחקנים”. חשוב להכיר אותם — הן להבנת האיום, הן כי זו שאלה נפוצה בראיונות:

- **White Hat (כובע לבן):** האקר אתי הפועל בהרשאה ולמטרות הגנה. זה אנחנו.
- **Black Hat (כובע שחור):** תוקף זדוני, ללא הרשאה, למטרות רווח/נזק.
- **Grey Hat (כובע אפור):** פועל ללא הרשאה מלאה אך לא בהכרח בזדון (למשל מוצא חולשה ומדווח — אך הפעולה עצמה לא הייתה מורשית).
- **Script Kiddie:** חסר ידע עמוק, מריץ כלים מוכנים של אחרים בלי להבין.

- **Hactivist**: תוקף ממניעים אידאולוגיים/פוליטיים (למשל Anonymous).
- **State-Sponsored / APT**: קבוצות מתקדמות במימון מדינות (Advanced Persistent Threat), עם משאבים עצומים.
- **Insider Threat (איום פנימי)**: עובד בארגון שמנצל את גישתו לרעה.

💡 **מדוע זה חשוב לבדיקה?** כשמתכננים בדיקת חדירה, מגדירים את "פרופיל התוקף" שאותו מדמים — למשל "תוקף חיצוני ללא פרטי גישה" מול "עובד זדוני עם חשבון משתמש רגיל". הפרופיל קובע את נקודת ההתחלה.

1.3 סוגי בדיקות חדירה (Types of Penetration Tests)

לפי כמות המידע שנמסר לבודק

- **Black Box (קופסה שחורה)**: הבודק מקבל מידע מינימלי (למשל רק שם דומיין). מדמה תוקף חיצוני אמיתי. איטי יותר אך ריאלי.
- **White Box (קופסה לבנה)**: הבודק מקבל גישה מלאה — קוד מקור, דיאגרמות, פרטי גישה. יסודי ומהיר יותר.
- **Grey Box (קופסה אפורה)**: אמצע — מידע חלקי (למשל חשבון משתמש רגיל). הנפוץ ביותר בפועל.

לפי סוג היעד (Engagement Types)

- **External Network** — תקיפת הנכסים החשופים לאינטרנט.
- **Internal Network** — תקיפה מתוך הרשת הפנימית (מדמה עובד/מכונה שנפרצה). כאן נכנס **Active Directory**.
- **Web Application** — חולשות באפליקציות (OWASP).web
- **Wireless** — רשתות Wi-Fi.
- **Social Engineering** — תקיפת הגורם האנושי (פישנינג).
- **Physical** — חדירה פיזית למתקן.

🔍 **הקורס הזה** מתמקד בעיקר ב-Web, (AD), Internal, External ו-Wireless — בדיוק כמו בדיקת חדירות מקצועית טיפוסית.

1.4 מושגי יסוד וטרמינולוגיה

לפני שנצלול, נגדיר מונחים שילוו אותנו לכל אורך הקורס. **בלבול בין המונחים האלה הוא טעות נפוצה של מתחילים:**

מונח	הגדרה	דוגמה
Vulnerability (חולשה)	חולשה או פגם במערכת	גרסת Apache ישנה עם באג ידוע
Exploit (ניצול)	קוד/טכניקה המנצלים חולשה	סקריפט שמפעיל את הבאג ומשיג שליטה
Payload (מטען)	מה שרץ אחרי הניצול	Shell שנפתח, הוספת משתמש
Threat (איום)	גורם פוטנציאלי לנזק	האקר, תוכנה זדונית
Risk (סיכון)	הסתברות × נזק	סיכון גבוה = חולשה קריטית בקלות ניצול
Attack Surface	סך נקודות הכניסה האפשריות	כל הפורטים, השירותים והדפים החשופים
Zero-Day	חולשה שאין לה עדיין תיקון	באג לא ידוע ליצרן

נוסחת הזהב: גישה $Vulnerability + Exploit + Payload$. כלומר: מוצאים **חולשה**, מפעילים עליה **Exploit**, שמריץ **Payload** שנותן לנו שליטה.

 **דוגמה מוחשית:** דלת נעולה עם מנעול פגום = **Vulnerability**. שיטת פריצת המנעול = **Exploit**. מה שאתה עושה אחרי שנכנסת (גונב/מצלם) = **Payload**.

1.5 חמשת שלבי ההאקינג האתי (The Five Stages)

זהו **הלב של הקורס**. כל בדיקת חדירה — בלי קשר ליעד — עוברת דרך אותה מתודולוגיה בסדר קבוע. הכלים משתנים, המתודולוגיה לא.

שלב 1 — איסוף מידע (Reconnaissance)

איסוף כמה שיותר מידע על היעד. מתחלק ל: - **פסיבי (Passive)**: ללא מגע ישיר — Google, LinkedIn, דלף מידע. - **אקטיבי (Active)**: מגע ישיר — סריקה עם כלים כמו nmap.

דוגמה: מציאת כתובות מייל של עובדים ב-hunter.io (פסיבי) ← מודול 5.

שלב 2 — סריקה ומיפוי (Scanning & Enumeration)

זיהוי פורטים פתוחים (Open Ports), שירותים (Services), גרסאותיהם וחולשות אפשריות.

דוגמה: גילוי שפורט 80 פתוח ומריץ Apache 2.4.49 — גרסה עם חולשת Path Traversal ידועה ← מודול 6.

שלב 3 — השגת גישה (Gaining Access / Exploitation)

ניצול חולשה שהתגלתה כדי לחדור למערכת.

דוגמה: הפעלת Exploit מתאים ב-Metasploit נגד ה-Apache הפגיע, וקבלת Shell ← מודול 7.

שלב 4 — שמירת גישה (Maintaining Access)

שמירה על הגישה גם לאחר אתחול/ניתוק — למשל התקנת "דלת אחורית" (Backdoor) או משתמש נוסף.

דוגמה: הוספת מפתח SSH כדי לחזור למערכת בכל עת ← מודול 11.

שלב 5 — טשטוש עקבות (Covering Tracks)

מחיקת לוגים, קבצים וכלים שהושארו, כדי שהחדירה לא תזוהה. בבדיקה **אתית** — המטרה היא לנקות אחריו ולהחזיר את המערכת למצבה.

⚠ טעות נפוצה: דילוג על שלב 1. מתחילים נוטים "לקפוץ" ישר לתקיפה. בפועל, **80% מהצלחת הבדיקה תלויה באיכות איסוף המידע**. תוקף שמכיר את היעד לעומק — מנצח.

💡 שאלת ראיון קלאסית: "תאר את חמשת שלבי ההאקנג האתי". שכן אותם בעל פה ובסדר הנכון:
Recon → Scanning → Gaining Access → Maintaining Access → Covering Tracks

1.6 היבטים משפטיים ואתיים

לפני **כל** בדיקה חייבים מסמכים משפטיים: **Scope (טווח):** אילו נכסים מותר לתקוף. מה שמחוץ ל-Scope — **אסור**. - **Rules of Engagement (RoE):** כללי ההתקשרות — שעות, סוגי תקיפה מותרים, אנשי קשר. - **NDA:** הסכם סודיות — הבודק נחשף למידע רגיש. - **Get-Out-of-Jail-Free Letter:** מכתב הרשאה חתום, שמוכיח שהפעולה מורשית.

⚠ חוק ברזל: בישראל, תקיפת מערכת ללא רשות היא עבירה פלילית לפי **חוק המחשבים, התשנ"ה-1995**. גם "רק כדי לבדוק" על מערכת של אחר = עבירה. תרגל **אך ורק** על המעבדה שלך או

1.7 הקמת המעבדה (Lab Setup)

כדי לתרגל בבטחה, בונים מעבדה וירטואלית מבודדת — מכונות וירטואליות (VMs) הרצות על המחשב, מנותקות מהרשת האמיתית.

רכיבי המעבדה

1. תוכנת וירטואליזציה (Hypervisor): VMware Workstation Player או VirtualBox (חינמיים).

2. מכונת תוקף: Kali Linux.

3. מכונות מטרה: Metasploitable 2, Kioptrix, ובהמשך מעבדת Windows/AD.

התקנת Kali — צעד אחר צעד

1. גלוש ל `kali.org` ← Get Kali ← Virtual Machines
2. בהתאם למעבד (64-bit) (VirtualBox או VMware), הורד את דמות ה-VM
3. מהאתר הרשמי VMware Workstation Player התקן
4. שהורדת VM-את קובץ ה (Extract) חלץ
5. Kali של `.vmx`-בחר את קובץ ה ← Open ← File ← Player ← VMware
6. Edit Virtual Machine Settings:
 - Memory (RAM): 2GB לפחות (4 GB מומלץ יש 8 GB+)
 - Processors: 2 ליבות
7. Play Virtual Machine
8. kali סיסמה / kali התחברות: משתמש

הגדרת רשת מבודדת — קריטי! 🛡️

ב- VM → Settings → Network Adapter בחר **Host-Only** או **NAT**:

מצב רשת	משמעות	מתי
NAT	ה-VM חולק את חיבור המארח, מבודד מהרשת המקומית	ברירת מחדל בטוחה
Host-Only	רשת סגורה בין ה-VMs והמארח בלבד, ללא אינטרנט	תרגול תקיפה בין מכונות
Bridged	ה-VM מקבל IP ברשת הביתית האמיתית	⚠️ הימנע — חושף את הרשת

Snapshots — הרגל שיציל אותך

לפני כל שינוי משמעותי, ב-VMware: VM → Snapshot → Take Snapshot. אם משהו נשבר — חוזרים בלחיצה. קח Snapshot מיד אחרי התקנה נקייה של Kali.

💡 פתרון תקלות נפוצות: - "VT-x is disabled" — יש להפעיל וירטואליזציה ב-Kali. - BIOS/UEFI. איטי — הגדל RAM ל-4GB, הקצה 2 ליבות. - אין רשת — ודא שהמתאם מחובר (Connected) ובמצב NAT.

1.8 סקירת Kali Linux

Kali Linux היא הפצת לינוקס (מבוססת Debian) לבדיקות חדירה, עם 600+ כלי אבטחה מותקנים מראש.

דבר ראשון אחרי התקנה — עדכון

```
sudo apt update && sudo apt full-upgrade -y
```

ניווט בסיסי בממשק

- **תפריט Applications** (לוגו Kali) — כלים לפי קטגוריות.
- **Terminal** — סביבת העבודה המרכזית; כאן "נחיה" כל הקורס.
- **Firefox** — הדפדפן המובנה (שימושי ל-Burp Suite).

קטגוריות הכלים — עם דוגמאות אמיתיות

קטגוריה	תפקיד	כלי לדוגמה	שימוש לדוגמה
Information Gathering	איסוף מידע	nmap	<code>nmap -sV 10.0.0.5</code>
Vulnerability Analysis	ניתוח חולשות	nikto	<code>nikto -h http://10.0.0.5</code>
Web Application	חולשות web	Burp Suite	HTTP לתעבורת Proxy
Password Attacks	תקיפת סיסמאות	hydra	<code>hydra -l admin -P rockyou.txt ...</code>
Exploitation	ניצול	Metasploit	<code>msfconsole</code>
Sniffing & Spoofing	האזנה	Wireshark	לכידת תעבורת רשת
Post Exploitation	לאחר חדירה	mimikatz	שאיבת סיסמאות מהזיכרון

אין צורך לשנן את כל הכלים עכשיו — נכיר אותם בהדרגה, כל אחד בשלב המתאים.💡

מבנה מערכת הקבצים (נקודות מפתח)

- `/etc` — קבצי הגדרות המערכת.
- `/home/kali` — תיקיית הבית שלך.
- `/usr/share/wordlists` — רשימות מילים לתקיפת סיסמאות (כולל `rockyou.txt`).
- `/opt` — כלים שהותקנו ידנית.
- `/tmp` — קבצים זמניים (שימושי בזמן תקיפה).

(את פקודות ה-Linux עצמן נלמד לעומק במודול 2 — יסודות Linux).

סיכום המודול

- האקינג אתי = בדיקה מורשית למציאת חולשות לפני התוקף, המגנה על ה-CIA Triad.
- מכירים את סוגי ההאקרים (White/Black/Grey ...) ואת סוגי הבדיקות (Black/White/Grey Box; External/Internal/Web ...).

- שולטים בטרמינולוגיה: **Vulnerability + Exploit + Payload = גישה**.
- **חמשת השלבים**: Recon → Scanning → Gaining Access → Maintaining Access → Covering Tracks.
- כל פעולה מחייבת **הרשאה משפטית** (Scope, RoE, NDA).
- הקמנו **מעבדה מבודדת** עם Kali (תוקף) + מטרות, והכרנו את Kali וארגו הכלים.

מילון מונחים מהיר

Recon · Enumeration · Vulnerability · Exploit · Payload · Attack Surface · Scope · RoE · CIA Triad · Hypervisor · Snapshot

מה הלאה?

→ **תרגילים** — `missions.md` (קל → קשה) · לאחר מכן **פתרונות** — `solutions.md` · **תרגול**
ותרחישים — `practice.md` → **המודול הבא: מודול 2 — יסודות Linux**

← **חזרה למפת הקורס**